DIGITAL FORENSICS & INCIDENT RESPONSE

Offline VM Disk Forensics: HSBox2 Analysis

ANALYST	TARGET APPLIANCE	FORENSIC METHOD	FLAG STATUS
white	HSBox2.ova (VMDK)	Dead-Box (Guestfish)	Verified Solved

1. Objective & Forensic Rationale

The objective of this investigation is to conduct offline forensics on the virtual appliance `HSBox2.ova` to extract hidden flags and identify user/attacker activities without booting the guest operating system.

DEAD-BOX FORENSICS PRINCIPLE

Booting a suspicious virtual machine can contaminate evidence by modifying access timestamps, executing autorun malware, or triggering automated log rotation. Utilizing `guestfish --ro` mounts the virtual disk directly in read-only mode inside a sandboxed QEMU appliance, ensuring complete cryptographic evidence preservation.

2. Toolset Overview

TOOL / COMMAND	FUNCTION	FORENSIC PURPOSE
`file HSBox2.ova`	Container Identification	Verifies that the OVA package is a POSIX tar archive.
`tar -xf HSBox2.ova`	Package Extraction	Extracts the OVF descriptor, VMDK virtual disk, and SHA-1 manifest.
`guestfish --ro -a ...`	Read-Only Disk Shell	Provides safe command-line access to disk partitions without VM boot.

3. Step 1: OVA Inspection & Disk Extraction

An OVA file is an uncompressed tar archive containing VM configuration and disk components. We inspect, extract, and verify file integrity:

```
(white@white)-[~/white/ibm/intern]$ file HSBox2.ova HSBox2.ova: POSIX tar archive (white@white)-[~/white/ibm/intern]$ tar -xf HSBox2.ova (white@white)-[~/white/ibm/intern]$ cat HSBox2.mf SHA1 (HSBox2.ovf) = a29d3dd3032ddb23a713ff9f4de9b9f94afe5ddc SHA1 (HSBox2-disk001.vmdk) = 269d1c1df3c4cd68ce4760c3af8a0a471998a7a3
```



Figure 1: Archive extraction revealing HSBox2-disk001.vmdk and manifest SHA-1 verification.

4. Step 2: Read-Only Disk Mounting with Guestfish

We initialize `guestfish` with `--ro` (read-only mode) to mount the ext4 partition at `/dev/sda1`:

```
(white@white)-[~/white/ibm/intern]$ sudo guestfish --ro -a HSBox2-disk001.vmdk ><fs> run ><fs> list-filesystems
/dev/sda1: ext4 /dev/sda5: swap ><fs> mount /dev/sda1 / ><fs> ls /root
.bash_history .bash_logout .bashrc .cache .mysql_history .nano_history .profile .viminfo finalflag.txt
```



Figure 2: Discovering /dev/sda1 (ext4), mounting to virtual root, and listing /root directory.

5. Step 3: Flag Retrieval & Absolute Path Requirement

Guestfish requires absolute paths starting with `/`. Relative paths trigger a download stub error. Running `cat /root/finalflag.txt` recovers the root flag:

```
><fs> cat finalflag.txt libguestfs: error: download: download_stub: path must start with a / character ><fs>
cat /root/finalflag.txt .----------. |.--------.| ||>run# || || || |"-------'| .-^---------^-. | ---~ |
"------------' root-flag{bbe4bc6f660e82677ed07254732eb6b3}
```

CAPTURED ROOT FLAG

root-flag{bbe4bc6f660e82677ed07254732eb6b3}



Figure 3: Output of finalflag.txt confirming successful flag capture.

6. Step 4: Forensic Artifact Analysis (Shell & Database)

Beyond capturing the flag, inspecting user history files in `/root` revealed anti-forensics activity and hardcoded database credentials:

6.1 Anti-Forensics & Log Cleansing (`.bash_history`)

```
><fs> cat /root/.bash_history ls truncate -s 0 /var/log/syslog truncate -s 0 /var/log/*log truncate -s 0 /var/log/apache2/*log ls -la rm .bash_history cat .bash_logout passwd reboot
```

- **Log Zeroing:** The user executed `truncate -s 0` on syslog, wildcard system logs, and apache2 access/error logs to eliminate intrusion traces.
- **Trace Deletion:** The user attempted to delete `.bash_history` and reset the root password with `passwd` before rebooting.

6.2 Database Configuration & Credential Exposure (`.mysql_history`)

```
><fs> cat /root/.mysql_history CREATE DATABASE pumpkins; CREATE USER admin@localhost IDENTIFIED BY 'admin@123'; GRANT ALL PRIVILEGES ON pumpkins.* TO admin@localhost; FLUSH PRIVILEGES;
```

- **Target Database:** MySQL database named `pumpkins` was initialized on the host.
- **Plaintext Credentials:** High-privilege database user created: `admin@localhost` with password `admin@123`.

7. Forensic Summary & Reference Cheat Sheet

ACTION	GUESTFISH COMMAND
Attach disk (Read-Only)	`sudo guestfish --ro -a <disk.vmdk>`
Launch backend appliance	`><fs> run`
Scan filesystems / partitions	`><fs> list-filesystems`
Mount target partition	`><fs> mount /dev/sda1 /`
List directory contents	`><fs> ls /root`
Display file contents	`><fs> cat /root/finalflag.txt`
Download file to host workstation	`><fs> download /root/finalflag.txt /tmp/flag.txt`
Exit session	`><fs> exit`

8. Key Artifacts & Verification Table

FORENSIC ARTIFACT	VALUE / EVIDENCE
Final Root Flag	root-flag{bbe4bc6f660e82677ed07254732eb6b3}
MySQL Database	`pumpkins`
MySQL Credentials	Username: `admin` | Password: `admin@123`
Disk Manifest SHA-1	`269d1c1df3c4cd68ce4760c3af8a0a471998a7a3`